ESTUDO DE CASO

Projeto ATestaPonto

Registro eletrônico de presença de funcionários em unidades escolares, com autenticação federada (Gov.br), QR Code e geolocalização.

Documento de referência — atividade SCRUM-14
“Elaborar estudo de caso do projeto ATestaPonto”

Documento vivo — atualizado conforme o projeto evolui.

01 Problema que o projeto resolve

O projeto busca resolver um problema real observado no registro de presença de funcionários em escolas — tendo como referência a **Escola Miguel Vicente Cury**, onde a solução está sendo baseada.

Tradicionalmente, esse registro é feito em um **caderno físico**, no qual o próprio funcionário anota sua presença manualmente. Esse método, além de ser uma forma antiga de controle, apresenta riscos e limitações concretas:

- Perda de registros em caso de dano ou extravio do caderno;
- Dificuldade de acesso e consulta aos dados já registrados;
- Ausência de um histórico organizado e centralizado de presença.

O ATestaPonto resolve esses problemas ao ser **totalmente digital/online**: elimina o risco de perda física dos dados e facilita significativamente a navegação, a busca e a consulta dos registros de ponto.

02 Contexto de uso

O contexto de uso do sistema são **escolas da rede pública estadual de ensino**. O projeto é desenhado para operar dentro da hierarquia administrativa típica desse ambiente — Secretaria de Educação (SEDUC), Diretorias Regionais de Ensino (DRE) e unidades escolares — garantindo que o controle de presença respeite essa estrutura territorial e de gestão.

03 Usuários e perfis envolvidos

O sistema reconhece dois grandes grupos de usuários: o **Funcionário**, que registra a própria presença, e os **Administradores**, organizados em uma hierarquia de perfis com diferentes escopos territoriais.

Perfil Funcionário

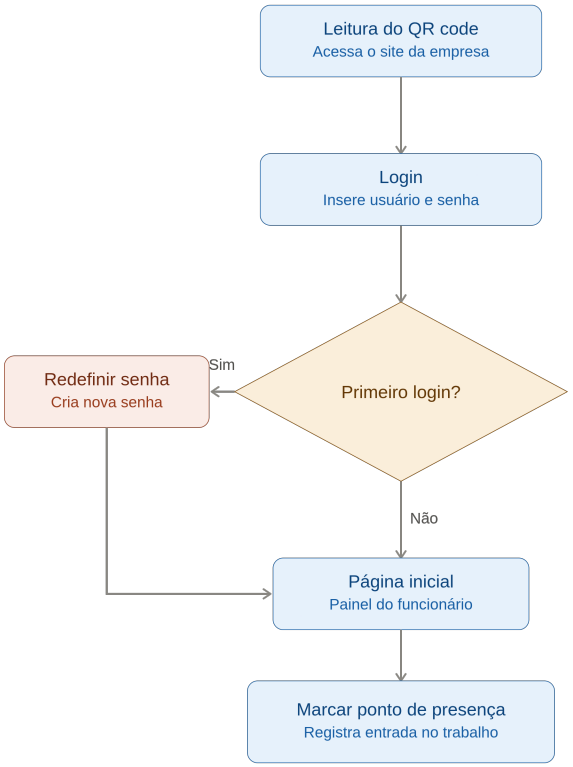
Realiza login (CPF ou e-mail + senha) e registra a própria presença via leitura de QR Code da unidade escolar combinada à geolocalização.

Perfis administrativos

Perfil	Escopo territorial
SEDUC	Estadual — todas as DREs e escolas
DRE (Diretoria Regional de Educação)	Regional — escolas da sua diretoria
Vice-Diretor	Unidade escolar específica
Secretaria (escolar)	Unidade escolar específica
Coordenador	Unidade escolar específica

04 Fluxo principal do sistema

O fluxograma abaixo representa o caminho principal do **funcionário** dentro do sistema, do primeiro contato até o registro efetivo do ponto de presença.



Fluxo de login, leitura de QR Code e registro de ponto do funcionário.

Passo a passo do fluxo:

- **1. Leitura do QR Code** — o funcionário acessa o site do sistema a partir do QR Code da unidade escolar;
- **2. Login** — insere usuário (CPF ou e-mail) e senha;
- **3. Verificação de primeiro acesso** — se for o primeiro login, o sistema exige a redefinição da senha temporária antes de prosseguir;
- **4. Página inicial** — o funcionário acessa o painel próprio;
- **5. Marcar ponto de presença** — o sistema registra a entrada/saída, validando QR Code e geolocalização.

05 Decisões técnicas relevantes

- **Migração gradual Node → Spring (Strangler Pattern):** O **atesta-gateway** (Node.js) é o gateway público; o Java/Spring Boot assume módulos de negócio gradualmente, sem reescrita total.
- **Fronteira única com o frontend:** O frontend só fala com o Node; a comunicação Node → Spring é interna (**/internal/****), autenticada via HMAC com timestamp e proteção anti-replay.
- **Autorização fail-closed:** Sem escopo territorial definido, não há acesso. O Gov.br apenas autentica; quem decide o que o usuário pode fazer é o próprio sistema.
- **SQL explícito, sem ORM:** JDBC no Spring e **mysql2** no Node — sem JPA/Hibernate ou query builder, com queries parametrizadas.

- **Segurança em camadas no Node:** Helmet, rate limiting, bcrypt, sessão própria + JWT, com Redis plugável (ligado/desligado por variável de ambiente).
- **Simulador Gov.br isolado (atesta-id):** Mantido separado do sistema real, permitindo substituição pelo Gov.br oficial em produção sem alterar a lógica de negócio.
- **Camada de services granular:** Separação clara das regras de negócio (escopo, papéis, credenciais, ponto, auditoria) dos controllers.
- **BrasilAPI v2:** Usada para validação de CEP e obtenção de coordenadas no cadastro de escolas, sem necessidade de chave de API.
- **Validação dupla no registro de ponto:** QR Code da escola + geolocalização dentro de um raio configurável, reduzindo fraude de ponto.
- **Auditoria dedicada:** Serviço próprio (**auditLogService**) para rastrear ações administrativas sensíveis.

06 Evolução das funcionalidades

Maio/2026 — MVP inicial

Primeiras versões do projeto, ainda como TCC. Formulário de localização, primeiros testes com QR Code, estrutura visual inicial e primeira tentativa de autenticação de admin.

Junho/2026 — Fundação da autenticação

Integração do simulador Gov.br fake (atesta-id), primeira versão funcional do servidor, reestruturação de rotas/API e primeiros ajustes de segurança.

Julho/2026 — Infraestrutura e deploy

Preparação dos serviços Express para deploy (Vercel), adição de Redis (sessão e banco remoto), SSL, e melhorias de UX no login.

Agosto/2026 — RBAC e autorização real

Substituição do admin fixo por fluxo real via Gov.br → modelo de usuário administrativo → sessão. Autorização por perfil e escopo, ciclo de vida de acessos e RBAC aplicado às leituras de ponto.

Setembro/2026 — Gestão de acessos e matriz de delegação

Concessão de acessos conforme regras de delegação e escopo, matriz real de capacidades RBAC no dashboard, e fluxo de primeiro acesso com troca obrigatória de senha.

Outubro/2026 — Migração para o Spring

Mês mais intenso de commits: início efetivo da migração de domínios de negócio (escolas, DREs, relatórios, autenticação administrativa) para o backend Java, mantendo o Node como gateway único.

Padrão geral: o projeto evoluiu de um protótipo de TCC (ponto + QR Code + geolocalização) para um sistema com autenticação federada real, infraestrutura de produção (Redis, deploy), controle de acesso hierárquico amadurecido (RBAC completo) e, atualmente, migração ativa de domínios de negócio para o Spring, preservando o Node como porta de entrada única.

07 Resultados e limitações atuais

Resultados

- Núcleo funcional operacional: autenticação federada, RBAC hierárquico completo (6 perfis administrativos + funcionário), registro de ponto via QR Code + geolocalização e gestão completa de acessos.
- Migração Node → Spring avançando com validação formal: módulos já migrados (acessos, cargos, QR, escolas, diretorias, relatórios) passaram por homologações com centenas de verificações, todas com resultado final **PASSOU**.
- Segurança testada ativamente: tentativas deliberadas de quebra (replay de HMAC, cookies expirados, filtros forjados de território) foram bloqueadas como esperado.
- Relatórios administrativos funcionais nos três formatos — diário, semanal e hierárquico —, respeitando o escopo territorial do administrador autenticado.

Limitações atuais

- Migração incompleta: convivência das stacks Node e Spring é o estado normal atual, não o estado final.
- Sem suíte de testes automatizados no gateway Node — a cobertura de testes concentra-se hoje no backend Spring.
- Validação majoritariamente em ambiente descartável/simulado (MySQL e Redis efêmeros, Gov.br simulado), sem confirmação equivalente em produção real.
- Já foram identificadas e corrigidas falhas de escopo durante homologação (ex.: acesso indevido fora do território), indicando que o controle territorial ainda está sob ajuste fino.
- Autenticação Gov.br real ainda não integrada — todo o fluxo de login é validado contra o simulador local (atesta-id).
- Entrega da senha temporária ao funcionário depende de canal seguro definido manualmente pela escola, sem mecanismo automatizado.
- Dependência da precisão de geolocalização do dispositivo do funcionário, sem alternativa documentada para falhas de GPS/sinal.

Documento vivo, referente à atividade **SCRUM-14 — “Elaborar estudo de caso do projeto ATestaPonto”**. Deve ser atualizado conforme o projeto evoluir.